

Unit 1: Introduction to Computer Security

Lecturer: Binod Chandra Shrestha

Computer Security/ Cybersecurity/ IT Security

- The protection of information system from theft/ damage to hardware, the software and information on them, as well as from disruption or misdirection of the services they provide.
- Includes controlling physical access to the hardware as well as protecting against harm that may come via network access, data and code injection due to malpractice by operators, whether intentional, accidental or due to them being tricked into deviating from secure procedure.
- Computer system also includes smartphones, smart television, any device as a part of internet of thing (IoT).
- Network include not only the internet and private data network, but also bluetooth, WiFi etc.

Internet Security

- Branch of computer security specifically related to the internet, browser security and network security
- Its objective is to establish rule and measures to use against attacks over the internet.
- Internet is an insecure channel for exchanging information
- There is high risk of intrusion or fraud such as phishing.
- Different methods have been used to protect the transfer of data including encryption.

Cyberwarfare

- Actions by a nation-state to penetrate another nation's computers or networks for the purpose of causing damage or disruption.
- Also includes non-state attacker e.g. terrorist groups, companies, political or ideological extremist group, hacktivists and transnational criminal organization.
- Some countries have made it as an integral part of military strategy.

Information Security (InfoSec)

- Is the practice of defending information from unauthorized access, use, disclose, disruption, modification, inspection, recording or destruction.

Mobile Security

- Personal or business information are now stored in smartphones.
- Concerns security of information stored in smartphones.

Network Security

- Consists of the policies adapted to prevent and monitor unauthorized access, misuse, modification, or denial of computer network and network accessible resources.

Computer Crime or Cyber Crime

- Crime that involves a computer and a network.
- Computer may have been used in commission of a crime or it may be a target.
- Dr. Debarati Halder and Dr. K. Jaishankar define cyber crime as “Offences that are committed against individuals or group of individuals with a criminal motive to intentionally harm the reputation of the victim or cause physical or mental harm or loss to the victim directly or indirectly using modern telecommunication networks e.g. internet (chat rooms, emails, notice boards and group) and mobile phones (SMS/MMS).”
- e.g. hacking, copyright infringement, child pornography and child grooming (befriending and establishing an emotional connection with a child for child sexual abuse).

Vulnerability and Attacks

- Backdoors:
 - Any secret method of bypassing normal authentication or security control.
- Denial of Service (DoS) Attack:
 - Designated to make a machine or network resource unavailable to its intended users. e. g. entry password many times to lock the account.
- Direct Access Attacks:
 - An unauthorized user gaining physical access to a computer is most likely able to directly download data from it.

Basic components of security

- As per definition of NIST:
 - “Computer security is the protection afforded to an automated information system in order to attain the applicable objectives of preserving the integrity, availability and confidentiality of information system resources (includes hardware, software, firmware, information/ data and telecommunication).”
- This definition introduces following three basic components of computer security.
 - Confidentiality
 - Integrity
 - Availability

Security Triad



Confidentiality

- Confidentiality involves ensuring that only those who are authorized have access to specific assets and that those who are unauthorized are actively prevented from obtaining access.
- This term covers two related concepts:
 - Data Confidentiality: Assures that private or confidential information is not made available or disclosed to unauthorized individuals.
 - Privacy: Assures that individual control or influence what information related to them may be collected and stored and by whom and to whom that information may be disclosed.

Integrity

- Integrity is about ensuring that data has not been tampered with and, therefore, can be trusted. It is correct, authentic, and reliable.
- This term covers two related concepts:
 - Data Integrity: Assures that information and programs are changed only in a specified and authorized manner.
 - System Integrity: Assures that a system performs its intended function in an unimpaired manner, free from deliberate or inadvertent unauthorized manipulation of the system.

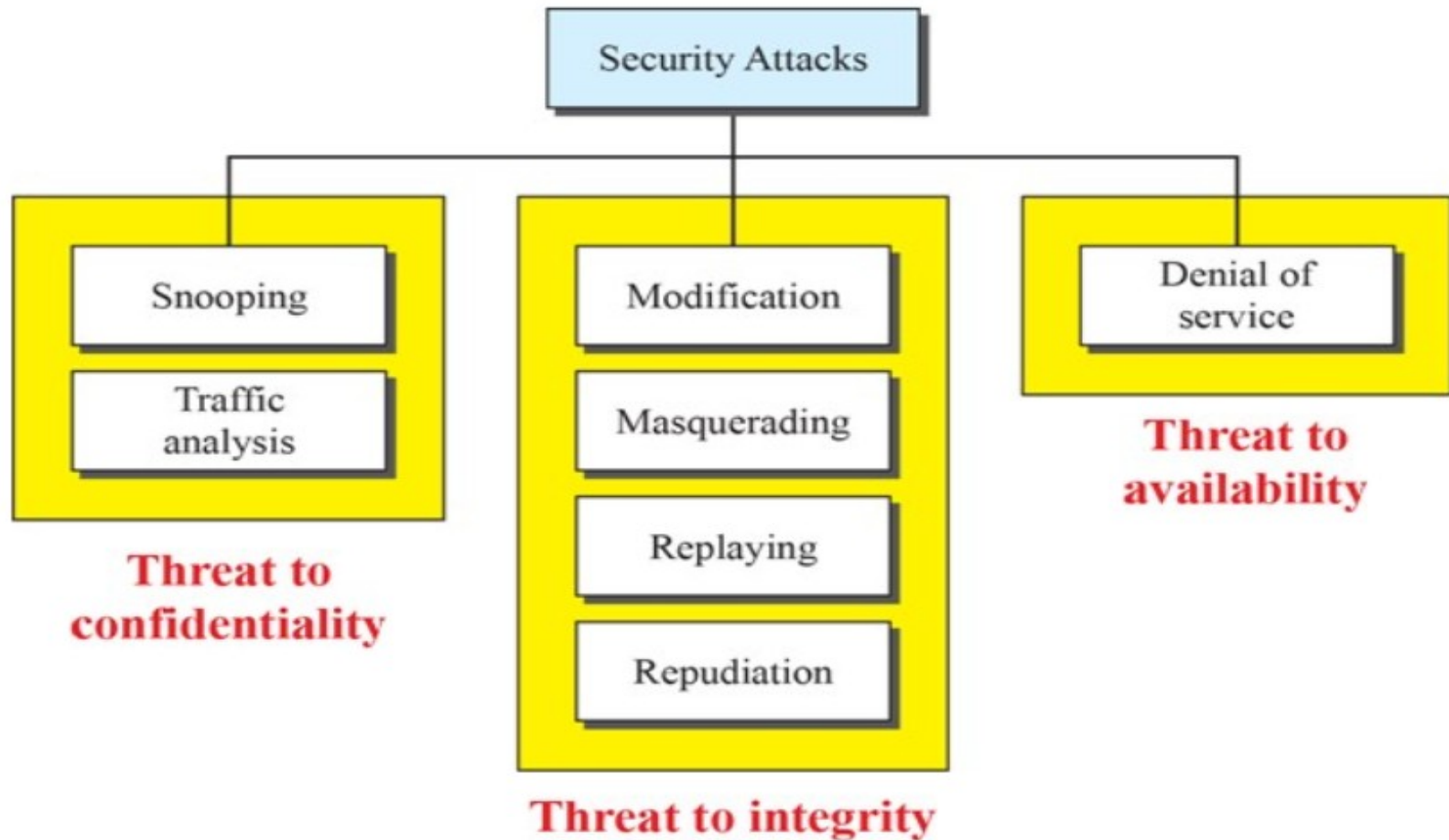
Availability

- Assures that systems work promptly and service is not denied to authorized users.
- Availability means that *networks, systems, and applications are up and running*.
- It ensures that *authorized users have timely, reliable access to resources when they are needed*.

Security threats

- A threat is potential violation of security. The violation need not actually occur for there to be a threat. The fact that the violation might occur means that those actions that could cause it to occur must be guarded against (or prepared for). Those actions are called attacks. Those who execute such actions or cause them to be executed, are called attackers.
- There are four broad classes of threats:
 - Disclosure (unauthorized access to information)
 - e. g. Snooping
 - Deception (acceptance of false data)
 - e. g. Modification, Masquerading, Repudiation of Origin, Delay , Denial of Service
 - Disruption (interruption or prevention of correct operation)
 - e. g. Modification
 - Usurpation (unauthorized control of some part of a system)
 - e. g. Modification, Masquerading, Delay , Denial of Service

Taxonomy of Attacks in relation to Security Goals



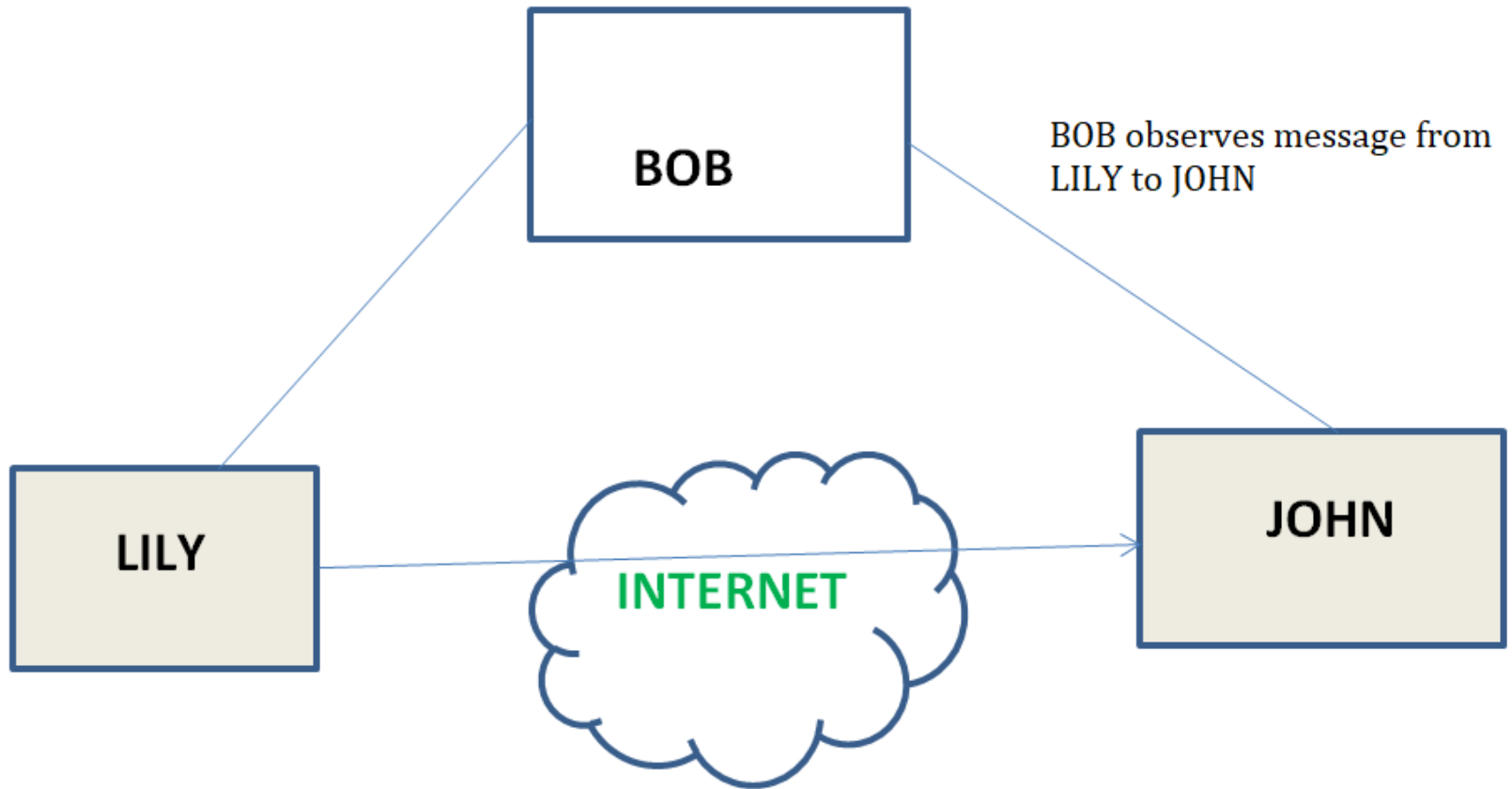
Example of CIA Triad

- Consider the example of a bank ATM, which can offer users access to bank balances and other information. An ATM has tools that cover all three principles of the triad:
 - It provides **confidentiality** by requiring two-factor authentication (both a physical card and a PIN code) before allowing access to data
 - The ATM and bank software enforce data **integrity** by ensuring that any transfers or withdrawals made via the machine are reflected in the accounting for the user's bank account
 - The machine provides **availability** because it's in a public place and is accessible even when the bank branch is closed.

Snooping

- It is the unauthorized interception of information, is a form of disclosure.
- It is passive type (some entity is listening or reading communications or browsing through files or system information).
- e. g. wire tapping in which a network is monitored
- Confidentiality service counter this threat.

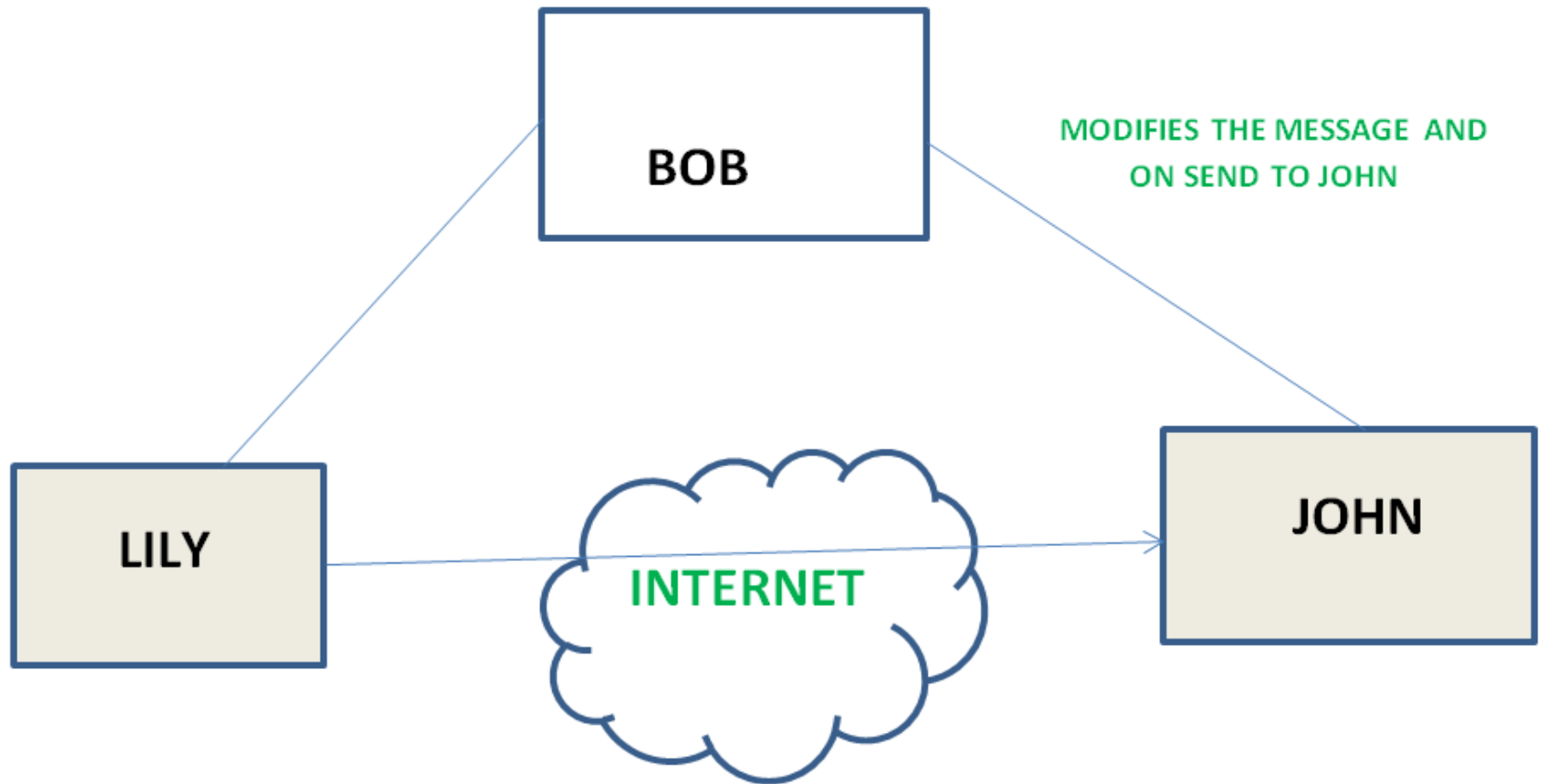
Snooping Cont...



Modification or Alteration

- An unauthorized change of information, covers three classes of threats.
 - Deception: in which some entity relies on the modified data to determine which action to take or in which incorrect information is accepted as correct and is released.
 - Disruption and Usurpation: If the modified data controls the operation of the system.
- Unlike snooping, modification is active type.
- e. g. active wire tapping (data moving across a network is altered.)
- The man-in-middle attack, in which an intruder reads message from the sender and sends (possibly modified) versions to recipient and the recipient and sender will not realize the presence of the intermediary.
- Integrity service counter this threat.

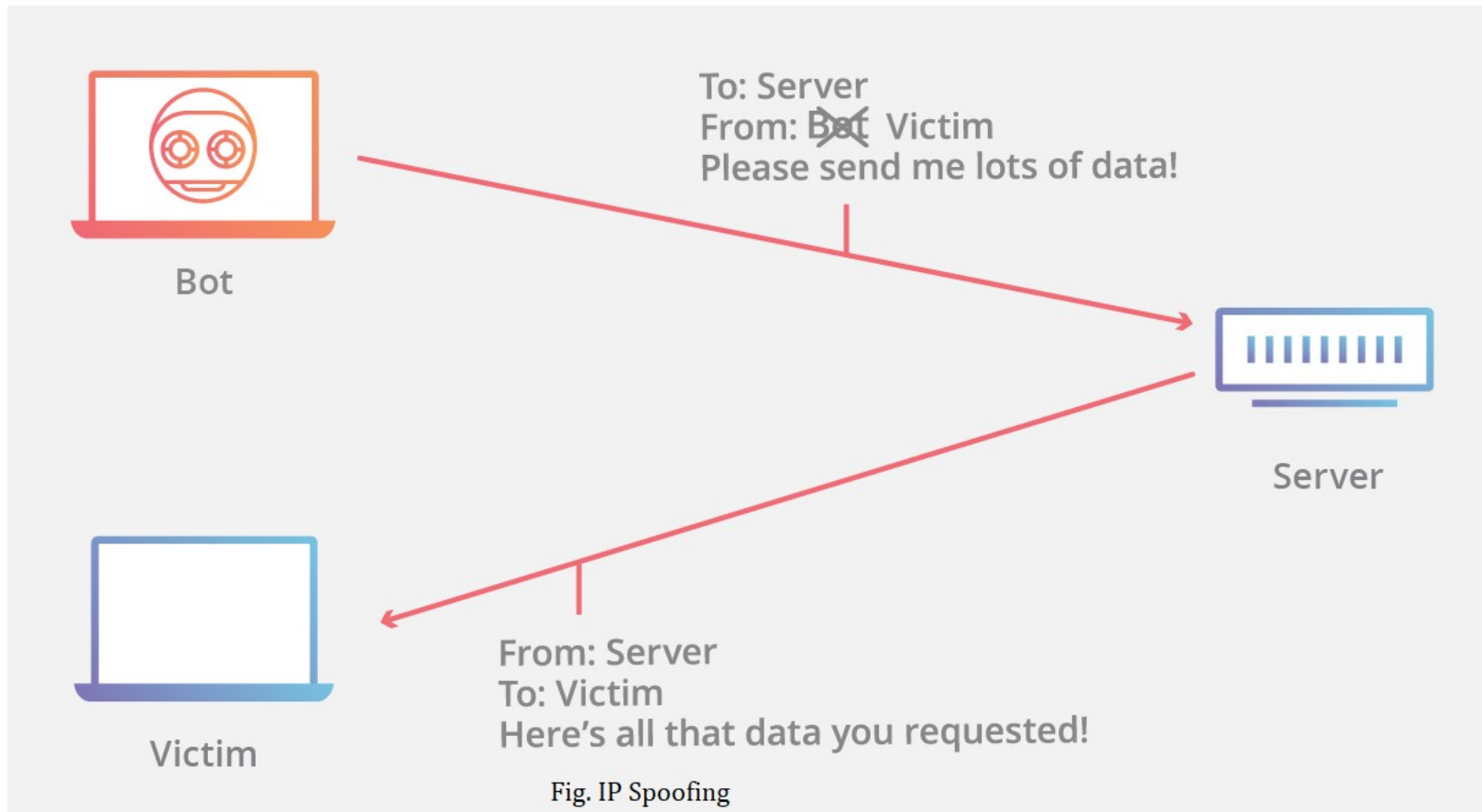
Modification Cont...



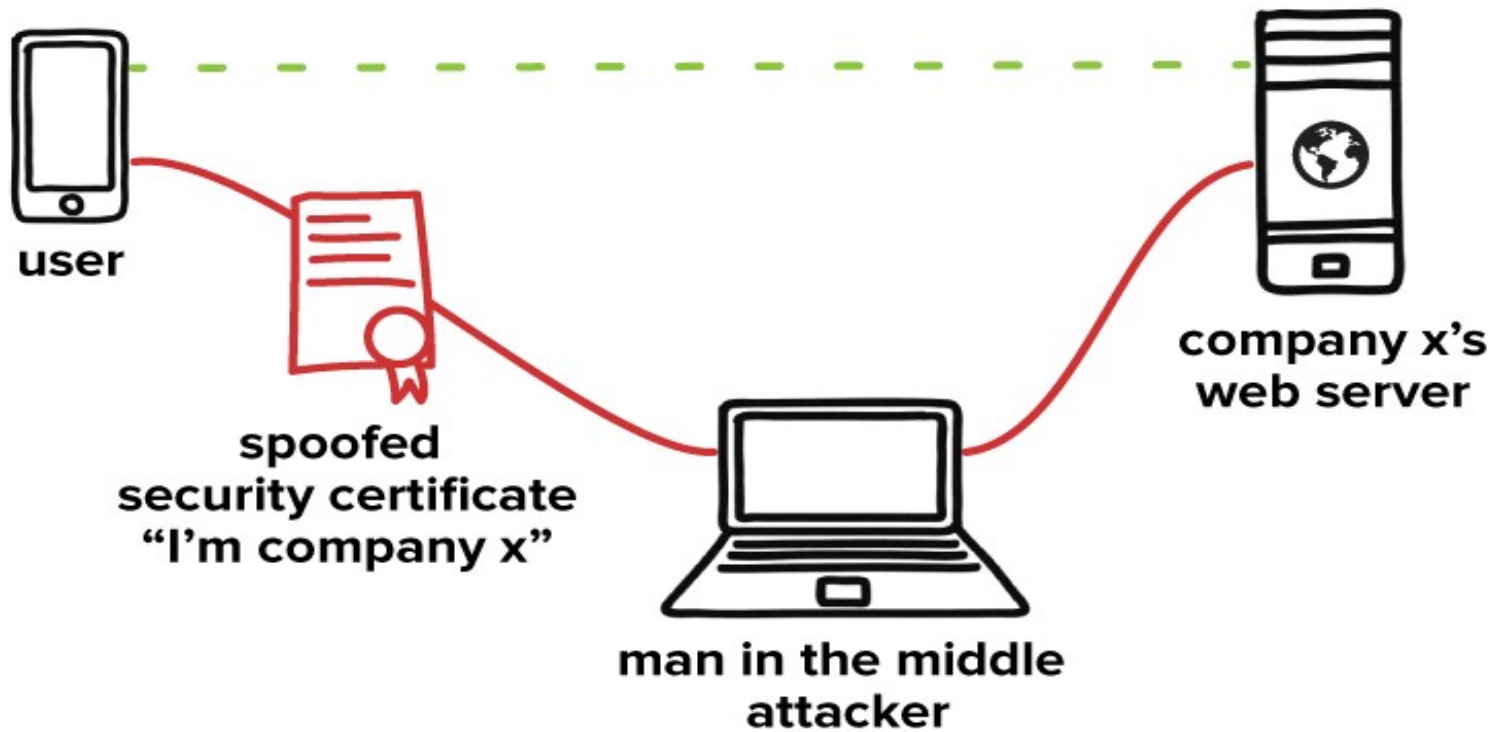
Masquerading or Spoofing

- An impression of entity by another, is a form of both deception and usurpation.
- It lures a victim into believing that the entity with which it is communicating is different entity.
- e. g. if a user tries to log into a computer across the internet but instead reaches another computer that claims to be the desired one, the user has been spoofed. Similarly, if a user tries to read a file, but an attacker has arranged for the user to be given a different file, another spoof has taken place.
- e.g. IP spoofing is the creation of Internet Protocol (IP) packets which have a modified source address in order to either hide the identity of the sender, to impersonate another computer system, or both.
- This may be a passive attack, but it is usually an active attack.
- Integrity service counter this threat.

Spoofing Cont...



Spoofing Cont...



Repudiation of Origin

- A false denial that an entity sent (or created) something, is a form of deception.
- e. g. Suppose a customer send a letter to a vendor agreeing to pay a large amount of money for a product. The vendor ships the product and demands payment. The customer denies having ordered the product and by law is therefore entitled to keep the unsolicited shipment without payment. The customer has repudiated the origin of letter. If the vendor cannot prove that the letter came from the customer, the attack succeeds. A variant of this is denial by a user that he created specific information or entities such as files.
- Integrity service counter this threat.

Repudiation of Origin

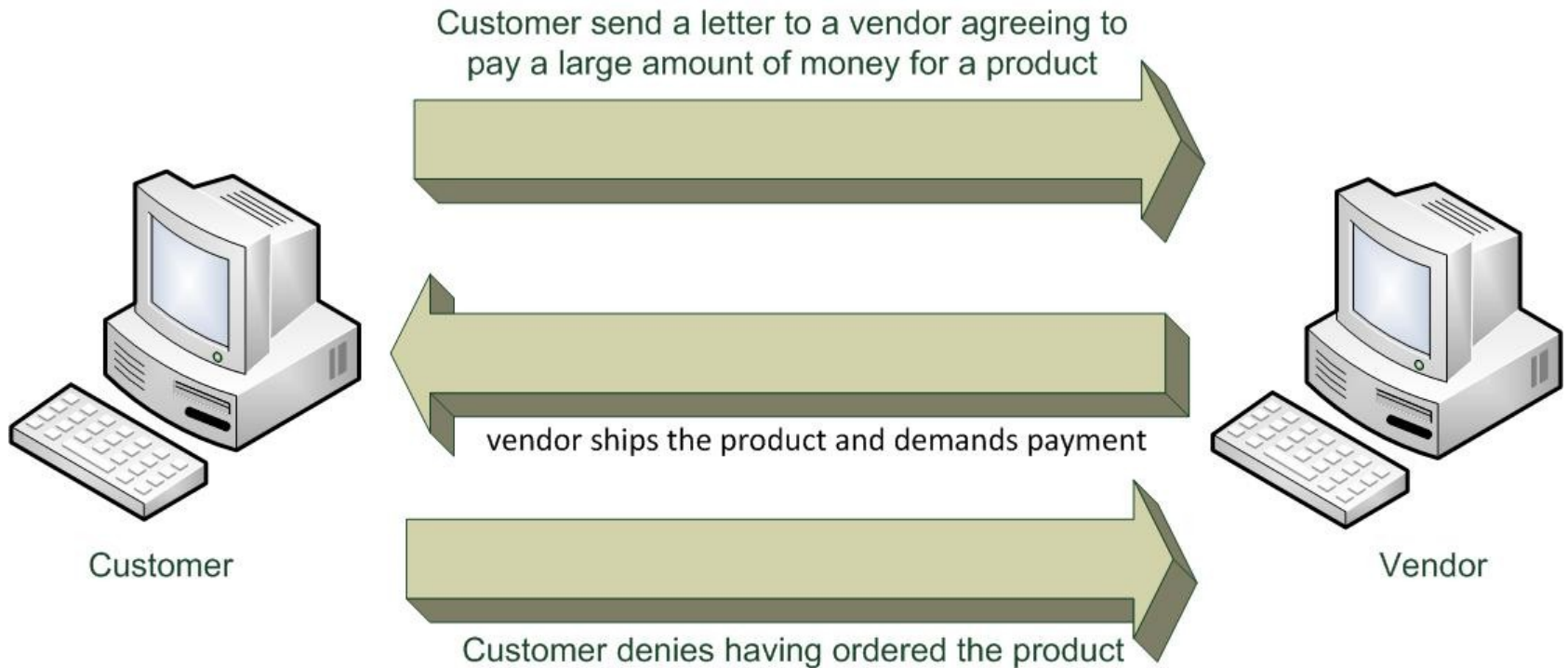


Fig. Customer repudiated the origin of letter

Repudiation
of Origin



I didn't send
that transfer



Bank



Denial of Receipt

- A false denial that an entity received some information or message, is a form of deception.
- e. g. Suppose a customer ordered a expensive product, but the vendor demands payment before shipment. The customer pays, and the vendor ships the product. The customer then asks the vendor when he will receive the product. If the customer has already received the product, the question constitutes a denial of receipt attack. The vendor can defend against this attack only by proving that the customer did, despite his denial, receive the product.
- Integrity and availability mechanisms guard against these attacks.

Denial of Receipt Cont...

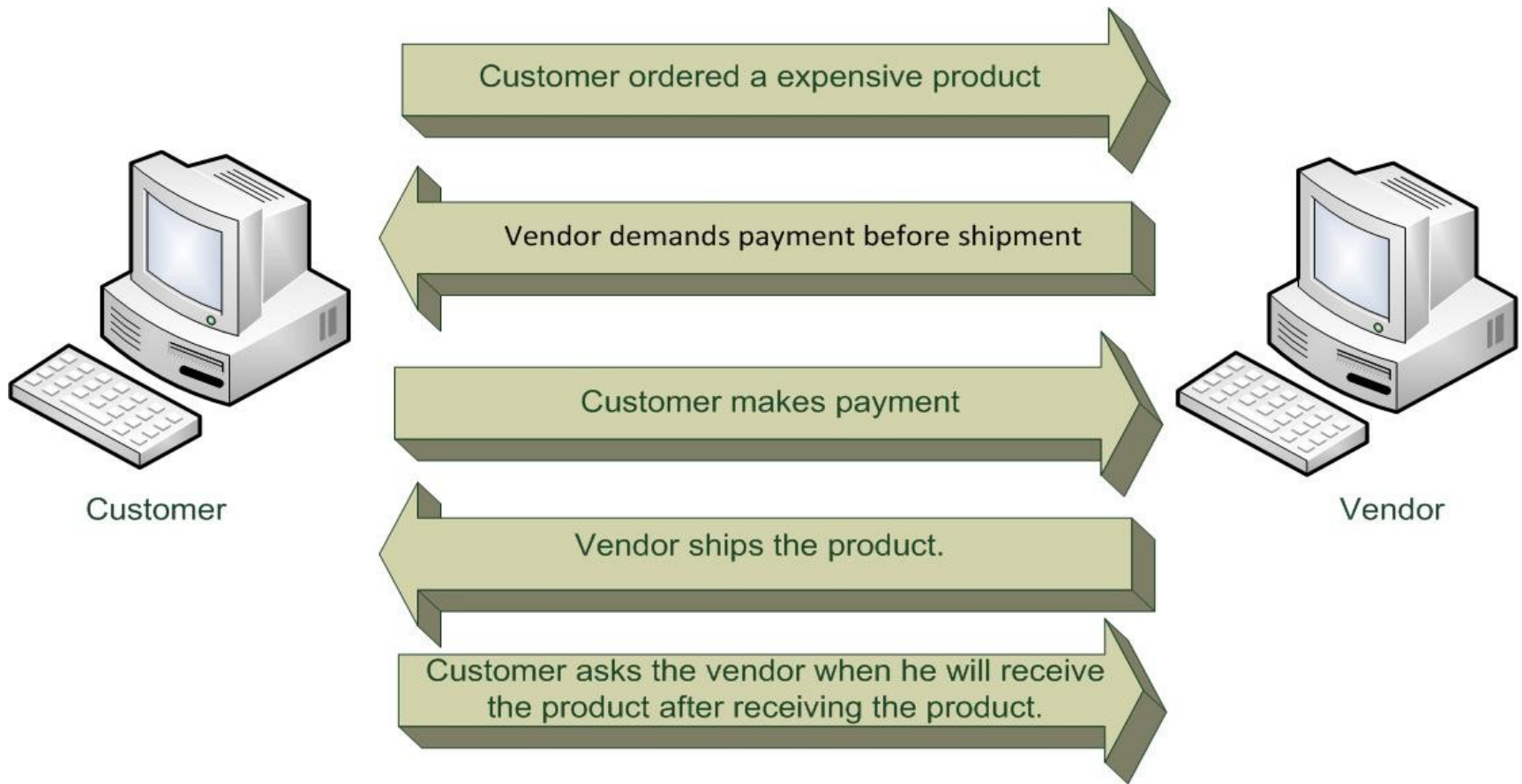
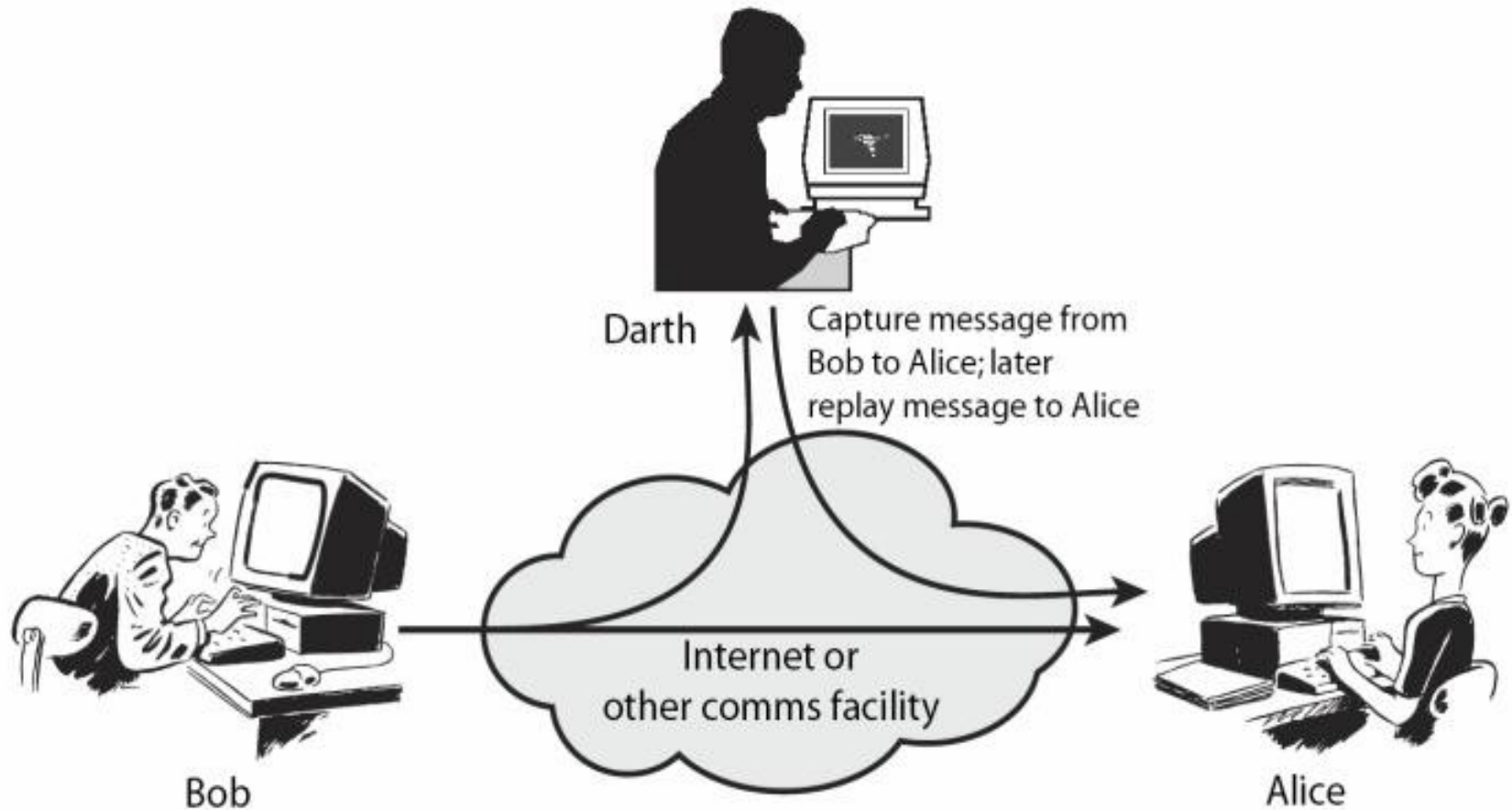


Fig. Denial of Receipt by Customer

Delay

- A temporary inhibition of service, is a form of usurpation, although it can play a supporting role in deception.
- Typically, delivery of a message or service requires some time t ; if an attacker can force the delivery to take more than time t , the attacker has successfully delayed delivery. This requires manipulation of system control structures, such as network components or server components and hence is a form of usurpation. Attacker might be able to masquerade the message and supply incorrect information.
- Availability mechanism can thwart this threat.

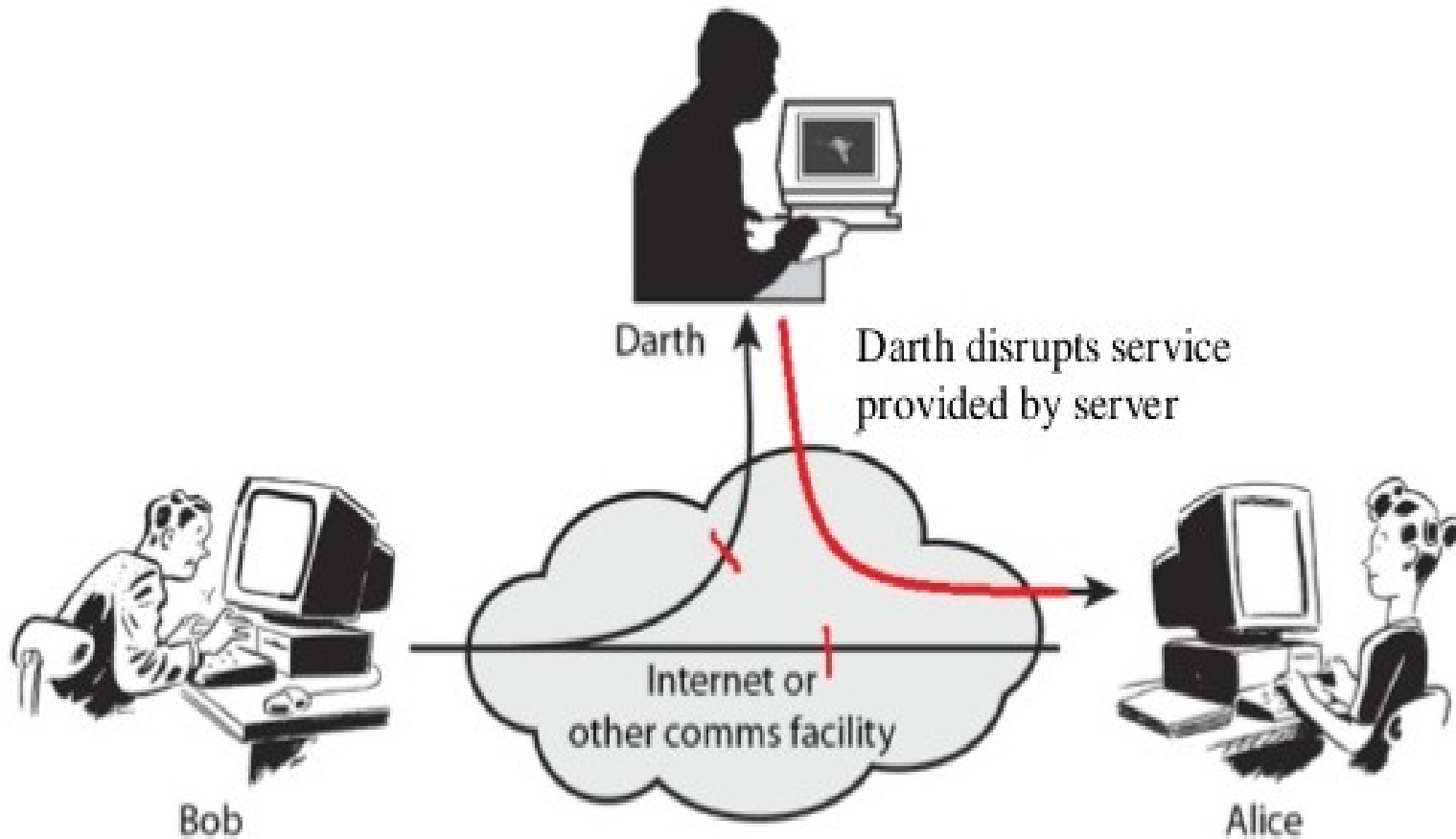
Delay Cont...



Denial of Service

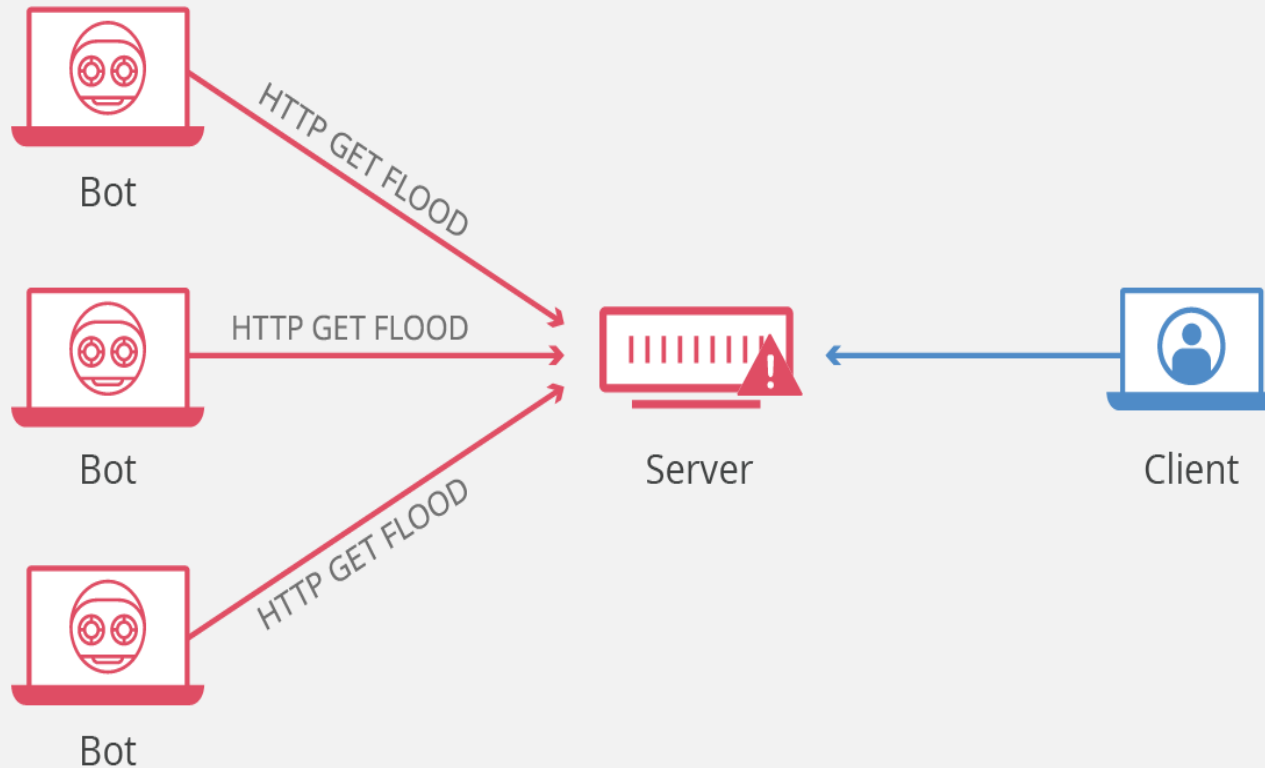
- A long term inhibition of service, is a form of usurpation, although it is often used with other mechanism to deceive.
- The attacker prevents a server from providing a service.
- The denial may occur at the source or destination or along the intermediate path.
- Denial of service poses the same threats as an infinite delay.
- Availability mechanisms counter this threat.

Denial of Service Cont...



Denial of Service Cont...

HTTP Flood Attack



Issues with Security

- Security Attack: any attack that compromises the security of information.
- Security Policy: is statement of what is, and what is not, allowed.
- Security Mechanism: a method, tool, or procedure for enforcing a security policy to detect, prevent or recover from a security attack.
- Security Services: A service that enhances the security of data processing systems and information transfers. A security service makes use of one or more security mechanism.

Security Services

```
graph TD; A[Security Services] --> B[Data Confidentiality]; A --> C[Data Integrity]; A --> D[Authenticity]; A --> E[Non Repudiation]; A --> F[Access Control]; C1[-Anti-change] --- C2[-Anti-replay]; D1[-Anti-change] --- D2[-Anti-replay]; E1[-Proof of origin] --- E2[-Proof of Delivery];
```

Data
Confidentiality

Data
Integrity

-Anti-change
-Anti-replay

Authenticity

-Anti-change
-Anti-replay

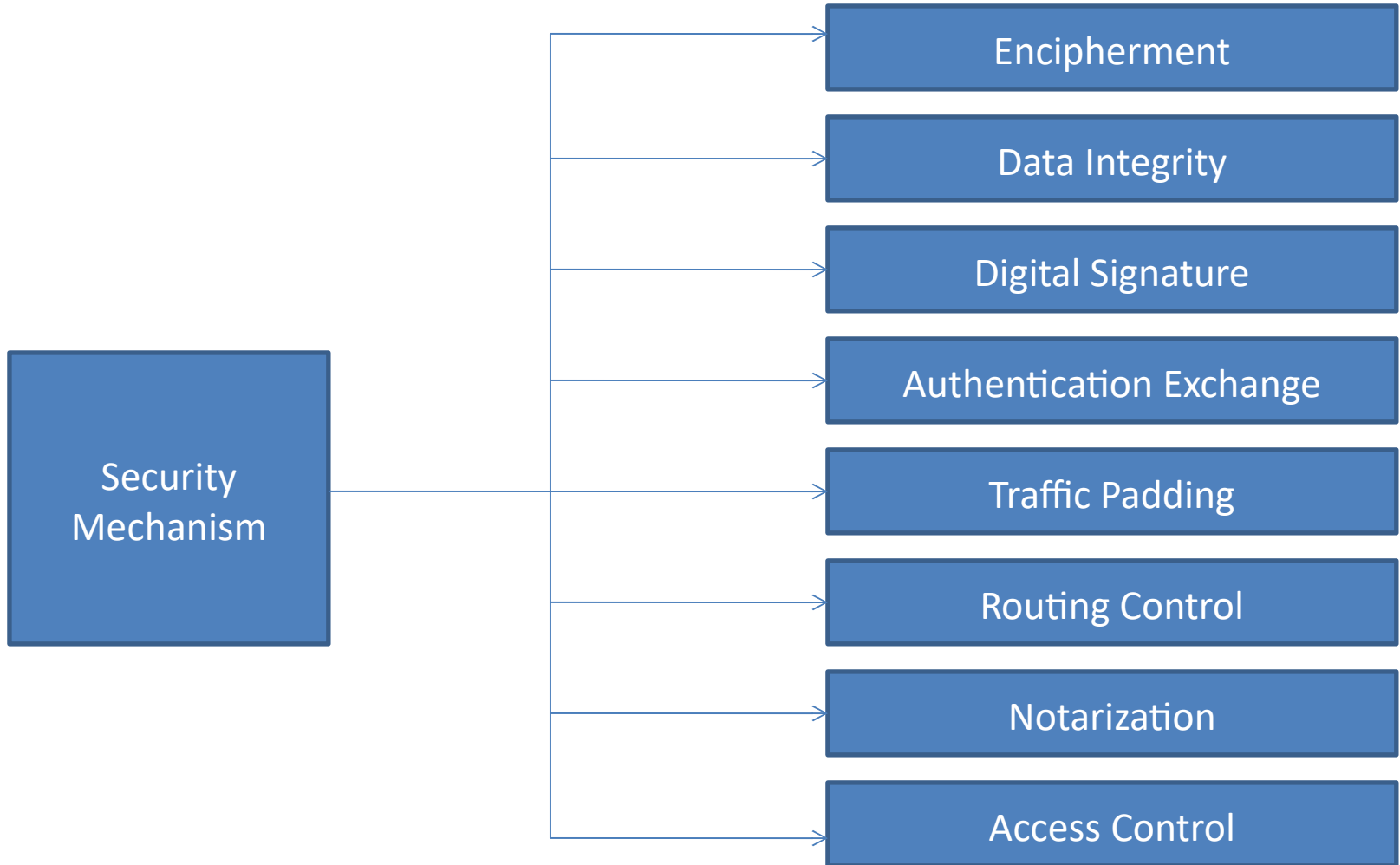
Non
Repudiation

-Proof of origin
-Proof of Delivery

Access
Control

Security Services

- Authentication: assures recipient that the message is from the source that it claims to be from.
- Access Control: controls who can have access to resource under what condition.
- Availability: available to authorized entities for 24/7.
- Confidentiality: information is not made available to unauthorized individual.
- Integrity: assurance that message is unaltered.
- Non Repudiation: protection against denial of sending or receiving in the communication.



Relationship between Security Services and Security Mechanisms

Security Service	Security Mechanism
Data Confidentiality	Encipherment and routing control
Data Integrity	Encipherment, digital signature, data integrity
Authentication	Encipherment, digital signature, authentication exchange
Non Repudiation	Digital Signature, data integrity, notarization
Access Control	Access control mechanism

Operational Issues

- Any useful policy and mechanism must balance the benefit of the protection against cost of designing, implementing, and using the mechanism. This balance can be determined by analyzing the risks of a security breach and likelihood of it occurring.
- Following are the analysis for operational issues:
 - Cost benefit analysis
 - Risk analysis
 - Laws and customs

Cost benefit Analysis

- The benefit of computer security are weighted against their total cost.
- If the data or resources cost is lesser than value of their protection, adding security is not cost effective.
- Is it cheaper to prevent or recover?

Risk Analysis

- To determine whether an asset should be protected, and to what level, requires analysis of potential threats against that asset and the likelihood that they will materialize.
- Risk is function of environment.
- e. g. Attacker is foreign, there is no risk if the computer is not connected to internet.
- The risks change with time.
- The many risks are quite remote but still exist.

Laws and Customs

- Laws restrict the availability and use of technology and affect procedural controls.
- Any policy and any selection of mechanisms must take into account legal considerations.
- Laws are not the only constraints on policies and selection of mechanisms. i.e. socially acceptable.
- The issue that laws and customs raise is the issue of psychological acceptability.
- Users may rely on that service to protect their data, when in reality their data is unprotected.

Human Issues

- Implementing computer security controls is complex and in a large organization procedural controls often become vague. The designers, implementers and maintainers of security control are essential to the correct operation of those controls.
- Following are the human issues:
 - Organizational problems
 - People problems

Organizational Problems

- Security provides no direct financial reward to the user.
- It limits losses, but it also requires the expenditure of resources.
- Power and responsibility
- Financial benefit

People Problems

- Heart of any security system is people. This is true or computer security too.
- There are two types of people:
 - Outsiders: people have some motive to attack an organization and are not authorized to use that organization's system are called outsiders and can pose a serious threat.
 - Insiders: Insiders are those employees who are authorized to use the system and misuse the authorized privilege.

Types of Security Policies

- A military security policy (also called a governmental security policy) is a security policy developed primarily to provide confidentiality.
- A commercial Security policy is a security policy developed primarily to provide integrity. These policies, called transaction-oriented integrity security policies are critical to organization that require consistency of database.
- A confidentiality policy is a security policy dealing only with confidentiality.
- An integrity policy is a security policy dealing only with integrity.

Access Control and Access Control Matrix

- Access control:
 - it is an ability to permit or deny the use of particular resources by a particular entity.
- Access Control Matrix:
 - The simplest framework for describing a protection system is the access control matrix model, which describes the rights of user over files in a matrix.
 - The set of all protected entities is called set of object 'O'.
 - The set of subject 'S' is the set of active objects such as processes and users.

	File 1	File 2	Process 1	Process 2
Process 1	Read, write, own	read	Read, write, execute, own	write
Process 2	append	Read, own	read	Read, write, execute, own

Fig. An access control matrix: The system has two processes and two files. The set of Right is {read, write, execute, append, own}

	Counter	inc_ctr	dec_ctr	manager
inc_ctr	+			
dec_ctr	-			
manager		call	call	call

Fig. An access control matrix: Rights in a program. The set of Right is {+, -, call}

Types of Access Control

- Discretionary access control (DAC) also called an identity based access control (IBAC): If an individual user can set an access control mechanism to allow or deny access to an object.
- Mandatory access control (MAC) occasionally called rule based access control: when a system mechanism controls access to an object and an individual user cannot alter that access, the control is MAC.
- An originator controlled access control (ORCON) or ORGCON) bases on the creator of an object or the information it contains.
- A role based access control: the ability, or need to access information depend on one's job functions. A role is collection of job function.

The Bell-LaPadula Model (BLM)

- It is based on confidentiality policy.
- It is one of the first models that was created to control access to data.
- The Bell LaPadula Model, as a finite state machine model, controls information flow for confidentiality with two security properties:
 - Simple: no read up
 - * (star): no write down
- The Simple Security Property states that a subject (Bob) may not read the information at a higher sensitivity level (no read up).
- The * (star) Security Property states that a subject (Bob) may not write information to an object at a lower sensitivity level (no write down).
- A problem with this model is that it does not deal with integrity of data.

Top Secret

Information can't flow
down to less secure level



Secret

Bob can't read up
If he is assigned a **Simple** property.



Bob can't write down
If he is assigned a **Star** property.



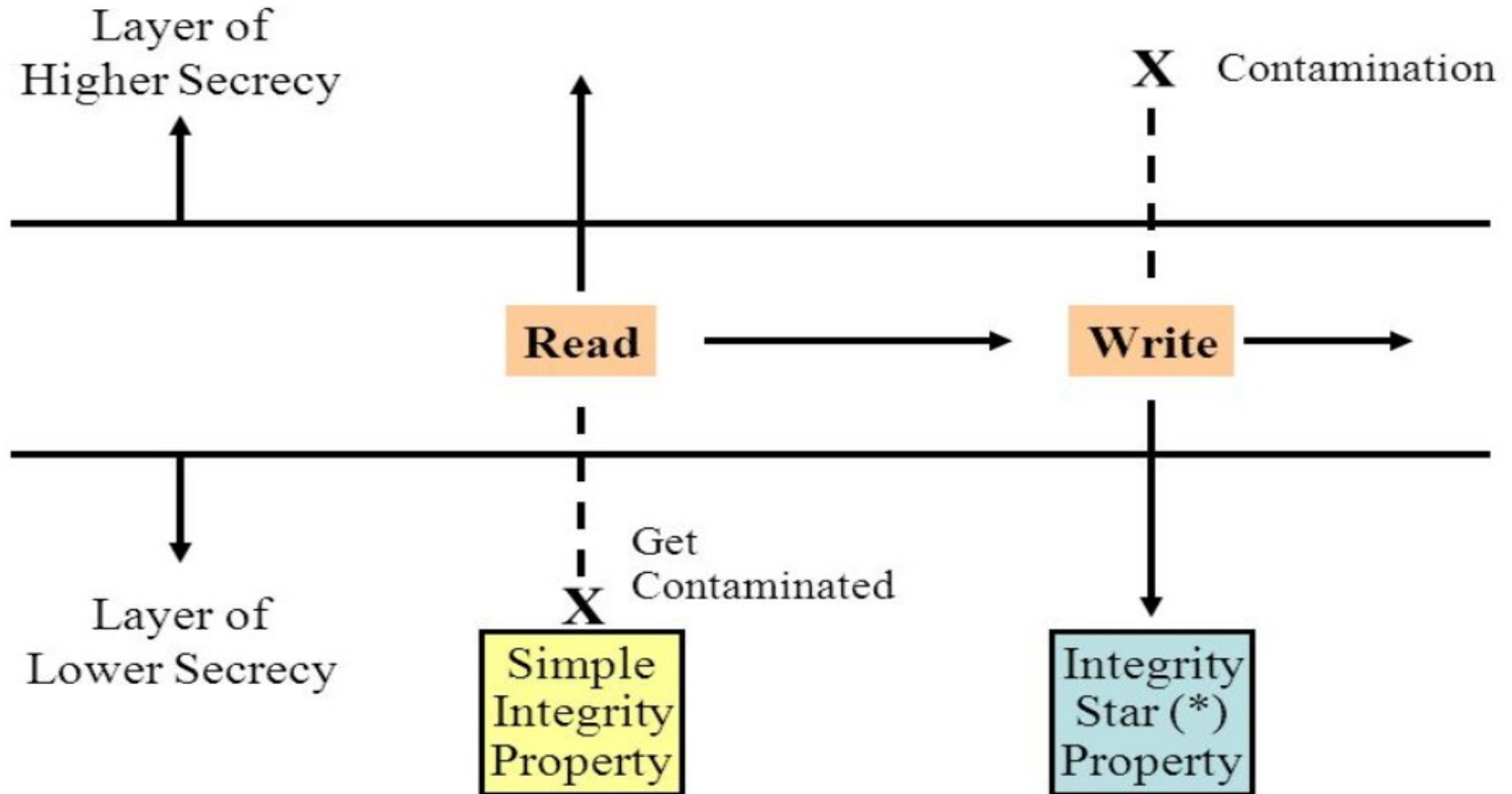
Confidential

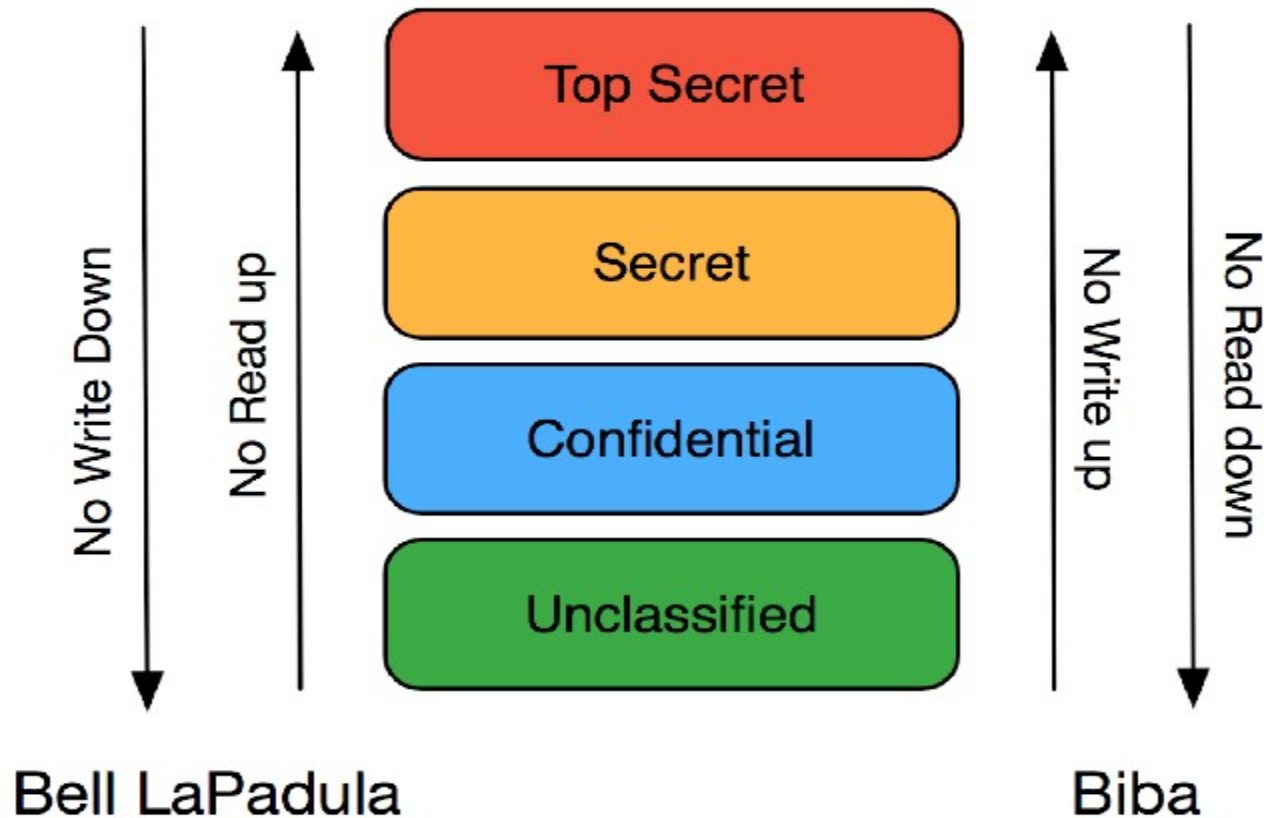
Information can't flow
down to less secure level

The Biba Model

- The primary motivation for creating this model is the inability of BLM to deal with integrity of data.
- The Biba model addresses the problem with the star property of BLM which does not restrict a subject from writing to a more trusted object.

The Biba Model Cont...





Comparision between Bell-LaPadula and Biba models. Bell-LaPadula provides confidentiality with the "no read up" and the "no write down" properties while Biba provides integrity with the "no write up" and the "no read down" properties.

Assignment-1

1. What are the three key components of computer security?
2. What do you mean by security threat? Explain its types.
3. How does spoofing work? Explain.
4. Show that the three security services- confidentiality, integrity and availability are sufficient to deal with the threats of disclosure, disruption, deception and usurpation.
5. How can you address the operational issues of the security? Explain.
6. Differentiate between passive attack and active attack.
7. What is Discretionary Access Control (DAC)?
8. What is a commercial Security Policy?
9. What is Mandatory Access Control (MAC)?
10. Explain access control matrix with an example?
11. Differentiate between Bell-LaPadula Model and Biba Integrity Model.